דוח מעבדה 2: השוואת מודלים לזיהוי חריגות בסייבר

השוואה בין Isolation Forest לבין Autoencoder with Embeddings

מגישות: ליאן מאור , נוי מלינק | **קורס:**AI-Driven Cybersecurity

---

חלק 6: השוואה כמותית בין המודלים (Quantitative Comparison)

בשלב זה נבחנו ביצועי שני המודלים על גבי מערך בדיקה (Test set) שכלל 792 אירועים (760 אירועים תקינים ו-32 התקפות). הטבלה שלהלן מרכזת את השוואת מדדי הביצוע: דיוק (Precision), רגישות (Recall), מדד F1, כמות התרעות השווא (False Positives) והחמצות התקיפה (False Negatives).

model	detected_anomalies	precision	recall	f1	false_positives	false_negatives
Isolation Forest	33	0.970	1.0	0.985	1	0
Autoencoder + embeddings	38	0.842	1.0	0.914	6	0

```
Agreement rate: 99.37%
Both: 33
Isolation Forest only: 0
Autoencoder only: 5
```

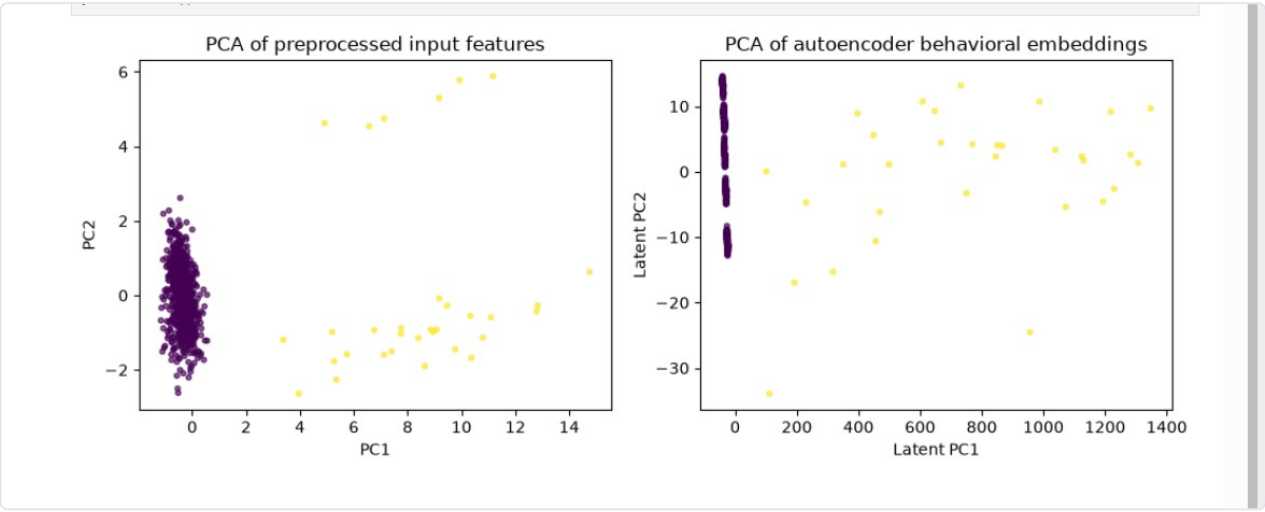
תמונה *1:* טבלת השוואת מדדי הביצוע ושיעור ההסכמה בין *Isolation Forest* לבין *Autoencoder*.

ממצאי ההשוואה הכמותית:

- **רגישות מרבית (Recall):** שני המודלים השיגו ציון Recall מושלם של 1.0 (100%), כלומר זיהו בהצלחה את כל 32 מתקפות הסייבר במערך הבדיקה ללא אף החמצה (`FN = 0`).
- **דיוק (Precision) וציון F1:** מודל Isolation Forest הציג עליונות מובהקת עם דיוק של 0.970 לעומת 0.842 במודל ה-Autoencoder, דבר שהוביל גם לציון F1 גבוה יותר (0.985 לעומת 0.914).
- **התרעות שווא ושיעור הסכמה:** שיעור ההסכמה הכללי בין שני המודלים עומד על 99.37%. שני המודלים הסכימו על 33 אירועים כחשודים. מודל Isolation Forest ייצר התרעת שווא אחת בלבד (`FP = 1`), בעוד שמודל ה-Autoencoder ייצר 6 התרעות שווא (`FP = 6`), מתוכן 5 מקרים שבהם רק ה-Autoencoder התריע.

חלק 7: מרחב התכונות המקורי מול מרחב ה-Embeddings ההתנהגותי

כדי להבין כיצד המודלים מייצגים את הנתונים, בוצעה הפחתת ממד ל-2 רכיבים ראשיים באמצעות PCA (Principal Component Analysis) משמאל מוצג מרחב התכונות המקורי שעבר עיבוד מקדים (המשמש את Isolation Forest), ומימין מוצג מרחב ה-Embeddings ההתנהגותי שנלמד על ידי שכבת ה-Latent ב-Autoencoder.



תמונה 2: היטל PCA של מרחב המאפיינים המקורי (משמאל) מול מרחב ה-Embeddings ההתנהגותי (מימין).

ניתוח היטלי ה-PCA:

- **מרחב התכונות המקורי (משמאל):** מרבית האירועים התקינים (בסגול) מרוכזים באשכול צפוף וקומפקטי סביב האפס. אירועי התקיפה (בצהוב) מפוזרים ורחוקים על גבי ציר PC1. פיזור ברור זה מסביר מדוע עצי הבידוד של Isolation Forest הצליחו לבודד את נקודות התקיפה בקלות ובדיוק רב.
- **מרחב ה-Embeddings של ה-Autoencoder (מימין):** שכבת ה-Latent מציגה דחיסה מלאה של דפוסי ההתנהגות התקינה לאשכול אנכי אחיד, בעוד שאירועי תקיפה נדחקים למרחקים עצומים על גבי ציר Latent לומד ייצוג קשרים סמנטיים, שבו כל Autoencoder-הדבר ממחיש כיצד ה .(ערכים המגיעים עד 1400) PC1 חריגה מההתנהגות המוכרת גורמת למרחק עצום במרחב הלטנטי.

חלק 8 ו-9: ניתוח מקרים של אי-הסכמה בין המודלים (Disagreement Analysis)

בחינת המקרים שבהם נרשמה אי-הסכמה (אירועים שסווגו כתקינים ב-Isolation Forest אך סומנו כאנומליה על ידי ה-Autoencoder) מספקת תובנות עמוקות לגבי אופן קבלת ההחלטות באבטחת מידע ובקרב אנליסטים בצוות SOC.

	user	country	device	protocol	hour	failed_attempts	distance_km
870	admin01	IL	admin_workstation	VPN	16	0	4.156354
372	analyst02	IL	managed_laptop	HTTPS	10	1	31.692761
2688	admin01	IL	admin_workstation	HTTPS	9	0	22.362931
2975	developer01	IL	developer_workstation	HTTPS	11	2	0.642864

session_minutes	bytes_out_mb	is_attack	if_score	if_pred	ae_score	ae_pred	models_agree
12.158062	3.901917	0	-0.062123	0	0.152365	1	False
13.494365	40.451243	0	-0.100038	0	0.074995	1	False
93.213104	4.188047	0	-0.067464	0	0.073012	1	False
23.068715	25.930824	0	-0.091810	0	0.048721	1	False

תמונה *3:* טבלת אירועי אי-ההסכמה *(אירועים שסווגו כאנומליה ב-Autoencoder בלבד).*

ניתוח 3 מקרים נבחרים מנקודת מבטו של אנליסט SOC:

מקרה 1: אירוע מס' 870 – משתמש admin01

- **1. המודל שהתריע:** ה-Autoencoder זיהה כאנומליה (`ae_pred = 1`), בעוד ש-Isolation Forest סיווג כתקין (`if_pred = 0`).
- **2. הראיות התומכות:** שגיאת שחזור גבוהה ביותר ב-Autoencoder (`ae_score = 0.152`). מנהל המערכת התחבר באמצעות פרוטוקול VPN מתחנת עבודה, בעוד ששאר המאפיינים רגילים לחלוטין (מרחק קצר של 4.15 ק"מ, שעה 16:00, 0 ניסיונות כושלים).
- **3. האם מדובר בחריגה לגיטימית:** כן, זוהי חריגה שגרתית ותקינה (`is_attack = 0`). במהלך האימון, חיבורי מנהל בתחנת עבודה ייעודית דרך VPN היו נדירים יחסית לפרוטוקול HTTPS, ולכן ה-Autoencoder התקשה לשחזר את הצירוף הספציפי. עם זאת, אין כאן שום ערך מספרי חריג.
- **4. החלטת אנליסט SOC:** סגירת ההתרעה כהתרעת שווא (False Positive). המשתמש מוכר, הגישה בוצעה מתוך ישראל, בשעות העבודה המקובלות, וללא סימני חדירה נוספים.
- **5. טכניקת MITRE ATT&CK רלוונטית: T1078 (Valid Accounts)** – חשד ראשוני לשימוש לרעה בחשבון ניהול קיים דרך שער גישה מרחוק.

מקרה 2: אירוע מס' 372 – משתמשת analyst02

- **1. המודל שהתריע:** ה-Autoencoder התריע כאנומליה (`ae_pred = 1`), בעוד ש-Isolation Forest סיווג כתקין (`if_pred = 0`).
- **2. הראיות התומכות:** נפח תעבורה יוצאת גבוה וחריג של 40.45 MB (לעומת החציון הארגוני השגרתי העומד על 7.46 MB בלבד). שגיאת השחזור עמדה על 0.075.
- **3. האם מדובר בחריגה לגיטימית:** כן, חריגה תפעולית לגיטימית (`is_attack = 0`). מדובר באנליסטית שהורידה או שלחה דוח נתונים גדול במסגרת תפקידה השוטף (בשעה 10:00 בבוקר, ממחשב נייד מנוהל של החברה).
- **4. החלטת אנליסט SOC:** סגירת ההתרעה (False Positive). השימוש במחשב מנוהל של החברה ומיקום גיאוגרפי תקין שוללים זליגת מידע עוינת HTTPS-חיבור מוצפן ב ,(managed_laptop).
- **5. טכניקת MITRE ATT&CK רלוונטית: T1048 (Exfiltration Over Alternative Protocol)** – חשד ראשוני להוצאת מידע חריגה עקב נפח תעבורה יוצאת מוגבר.

מקרה 3: אירוע מס' 2975 – משתמש developer01

- **1. המודל שהתריע:** ה-Autoencoder התריע כאנומליה (`ae_pred = 1`), בעוד ש-Isolation Forest סיווג כתקין (`if_pred = 0`).
- **2. הראיות התומכות:** נרשמו 2 ניסיונות התחברות כושלים (`failed_attempts = 2`) לצד תעבורה יוצאת של 25.93 MB וציון שחזור של 0.0487.
- **3. האם מדובר בחריגה לגיטימית:** כן, פעילות תקינה לחלוטין (`is_attack = 0`). הקלדה שגויה של סיסמה פעמיים לפני התחברות מוצלחת היא טעות אנוש נפוצה ושגרתית, ואינה מצביעה בהכרח על מתקפת סייבר.
- **4. החלטת אנליסט SOC:** סגירת ההתרעה ללא הסלמה. מספר הניסיונות הכושלים רחוק מאוד מדפוס של מתקפת Brute Force אמיתית (שבמערך הבדיקה הגיעה לחציון של 11 ניסיונות). שעת ההתחברות (11:00) והמרחק (0.64 ק"מ) נורמטיביים לחלוטין.
- **5. טכניקת MITRE ATT&CK רלוונטית: T1110 (Brute Force / Password Guessing)** – חשד למתקפת ניחוש סיסמאות.

חלק 10: סיכום ומסקנות (Conclusion)

השוואת המודלים במעבדה זו ממחישה את ההבדלים המהותיים בין שיטת יערות בידוד מבוססת עצים לבין רשתות נוירונים עמוקות עם שיבוצים התנהגותיים:

- **דיוק מול רגישות (Precision & Recall):** שני המודלים הפגינו ביצועים מעולים באיתור כלל התקיפות הציג עליונות תפעולית ברורה עם Isolation Forest, עם זאת .(מושלם של 1.0, אפס החמצות (Recall עדיף של 0.985 לעומת 0.914 F1 ומדד ,Autoencoder-של 0.970 לעומת 0.842 בלבד ב Precision.

- **התרעות שווא (False Positives):** הניב התרעת שווא בודדת Isolation Forest (`FP = 1`), לעומת 6 התרעות שווא ב-Autoencoder (`FP = 6`). בסביבה מבצעית של חמ"ל סייבר (SOC), צמצום התרעות השווא הינו יעד קריטי למניעת "עייפות התרעות" (Alert Fatigue) ולייעול זמנם של האנליסטים.
- **סוגי האנומליות שזוהו:** מודל Isolation Forest מצטיין בזיהוי חריגות קיצוניות ומבודדות במרחב הנתונים הכללי (כגון מרחקים גיאוגרפיים עצומים, כמות חריגה מאוד של כישלונות כניסה או שעות לילה מאוחרות). לעומתו, ה-Autoencoder רגיש להפרות של קשרים התנהגותיים מורכבים ושילובים לא שגרתיים בין משתמש, סוג מכשיר ופרוטוקול, גם כאשר הערכים הבודדים אינם קיצוניים.
- **תרומת ה-Behavioral Embeddings:** שימוש בשכבות Embedding עבור מאפיינים קטגוריאליים מאפשר למודל ללמוד ייצוג סמנטי עשיר ויחסים רציפים בין משתמשים ומכשירים, בניגוד לקידוד שטוח (כמו One-Hot Encoding) שמייצר מרחב תכונות דליל וחסר משמעות יחסית.
- **מגבלות אימון על נתונים תקינים בלבד:** אימון מודל בלמידה בלתי מונחית (Unsupervised) על בסיס תעבורת שגרה בלבד גורם לרגישות יתר לשינויים לגיטימיים בהתנהגות העובדים (כגון מעבר לעבודה מהבית, שעות לא שגרתיות או תעבורת קבצים כבדה). במערכת ייצור ארגונית נדרש כיול סף (Threshold Tuning) שוטף ואיסוף נתוני שגרה מגוונים לאורך זמן.